STEAMGEARS.EU · RESEARCH

Sikkerhed: AI Engine

CVE-2026-110732 (lukket 1/11 2026)

Undersøgt 1/11 2026 · kun læsende requests mod produktion · gælder siden steamgears.eu, ikke dette repo

TL;DR

- Pluginnet **AI Engine (Meow Apps)** kører **3.8.9 og er inaktivt**, verificeret live 1/11 2026 (afsnit 0). Fix-versionen for **CVE-2026-110732** (CVSS 7.5, uautentificeret, fører til administrator-overtagelse) er 3.8.7, så **sagen er lukket**.
- **Handling: udført.** 3.8.9 er installeret og MCP-funktionen slået fra, så angrebsfladen er væk uafhængigt af versionsnummeret.
- Selve det endpoint der blev spurgt til, `/wp-json/mwai/v1/simpleAuthCheck`, er **korrekt lukket** (401 anonymt). Det er ikke der hullet er.
- **Ikke bekræftet udnyttet.** Vi har ikke sendt en skrivende request til OAuth-registreringen, fordi det ville oprette en klient i produktionsdatabasen. Status er "versionen er omfattet ifølge advisory", ikke "hullet er demonstreret".
- Versionen i afsnit 1–5 er historisk: den stammer fra `/wp-json/wp/v2/plugins`-snapshotet i `backup-2026-10-23/plugins.json` (23/10 2026), som viste 3.8.6. Live-verifikation lykkedes 1/11 via MCP — resultatet står i afsnit 0. Fuld versionsliste for alle 48 plugins: sikkerhed-plugin-versioner-2026-11-01.md.

0. Opdatering 1/11 2026 — sagen er lukket

Sitet kører nu **AI Engine 3.8.9** (over fix-versionen 3.8.7) og **pluginnet er inaktivt**. Kontrolleret samme dag via MCP-forbindelsen og anonyme HTTP-kald:

Tjek	Resultat
Version ifølge plugin-header (wp_get_plugins)	3.8.9
Status	inaktiv
/wp-json/mcp/v1/.well-known/oauth-authorization-server	404 — MCP-OAuth-fladen er væk
/wp-json/mwai/v1/simpleAuthCheck	404 — hele mwai/v1 er væk
Forside med ?cb=<random>	ingen mwai-/ai-engine/-markup → pluginnet loader reelt ikke
Forside og /faq/ uden query-param	stadig mwai-popup-container + ai-engine/themes/glass.css → gammel sidecache
/wp-content/plugins/ai-engine/changelog.txt	stadig = 3.8.1

To ting at tage med videre:

1. **Angrebsfladen er væk.** Den uautentificerede MCP-OAuth-registrering, som CVE-2026-110732 handler om, svarer 404, og pluginnet er slået fra. Sagen kræver ikke længere handling ud over oprydning.
2. **changelog.txt er ikke længere et versions-oracle.** Den står på 3.8.1 mens headeren siger 3.8.9 — brug wp-admin → Plugins, ikke filen, når versionen skal aflæses. (Afsnit 5's kommando 1 er derfor upålidelig.)

Tilbage (småtteri): purge W3TC-sidecachen så den gamle chatbot-markup forsvinder, blokér `changelog.txt`/ `readme.txt` i WAF'en (punkt 4 i afsnit 3 — stadig `200`), og kryds tjeklisten i afsnit 4 af.

1. Hvad der blev tjekket

Tjek	Resultat
GET /wp-json/mwai/v1/simpleAuthCheck	401 rest_forbidden — ruten findes, men afviser anonyme
POST samme rute	404 rest_no_route — ruten er kun registreret som GET
GET /wp-json/mwai/v1/mcp/status, /settings/options, /get_logs	401 — også lukket
GET /wp-json/mwai/v1 (ruteindeks)	200, ~110 ruter listet (normal WordPress-adfærd, afslører hvilke features er aktive)
GET /wp-content/plugins/ai-engine/changelog.txt	200 — nyeste post 3.8.1 (2026/09/24), men WordPress rapporterer 3.8.6. Filen er altså ikke opdateret i 3.8.2–3.8.6 og duer ikke som versionskilde
GET /wp-content/plugins/ai-engine/readme.txt, languages/ai-engine.pot, app/chatbot.js	454 / 455 fra Simplys WAF ("Checking your browser" / security incident) — versions-fingeraftryk kan ikke læses udefra
GET /wp-json/mcp/v1/.well-known/oauth-authorization-server	200, annoncerer registration_endpoint: /wp-json/mcp/v1/oauth/register
OPTIONS /wp-json/mcp/v1/oauth/register	Allow: POST — ruten accepterer POST
Forsiden	AI Engine-chatbot er aktivt i brug (mwai-popup-container, ai-engine/themes/glass.css)

Om versionsbestemmelsen: `/wp-json/wp/v2/plugins` kræver admin-adgang og blev læst 23/10, hvor den gav 3.8.6. Det er den eneste pålidelige kilde, fordi `changelog.txt` er statisk gammel og WAF'en blokerer de øvrige fingeraftryksfiler. Sitet kan være auto-opdateret siden — men 3.8.9 er nyeste, og alt under 3.8.7 er omfattet, så konklusionen ændrer sig ikke. Verificér den faktiske version i wp-admin før opdatering.

2. Fundet: versionen er omfattet

WPScan's liste for `ai-engine` (opdateret 31/10 2026) mod den installerede **3.8.6**:

Alvor	Sag	Rettet i	Rammer 3.8.6?
7.5 high	CVE-2026-110732 — Missing Authorization → administrator-overtagelse via uautentificeret MCP OAuth client registration (off. 29/10)	3.8.7	Ja
4.3 medium	Missing Authorization (off. 26/10)	3.8.7	Ja
4.2 medium	Subscriber+ begrænset sletning af mediefiler via metadata	3.8.5	Nej — rettet i 3.8.5
4.9 medium	Editor+ vilkårlig ændring af post-titel/uddrag (update_post_title, update_post_excerpt)	3.8.6	Nej — rettet i 3.8.6

Sitet er altså **kun** bagud på de to sager der blev rettet i 3.8.7 — men den ene af dem er den alvorlige. Bemærk at 3.8.6 var fix-versionen for editor-sagen, så nogen har holdt pluginnet nogenlunde opdateret; det er de sidste ni dage (3.8.7, 3.8.8, 3.8.9) der mangler.

Hvorfor CVE-2026-110732 er den vigtige

Det er den eneste af de to der er **uautentificeret**, og den ender i **administrator**. Patchstack beskriver den som «high priority / forventet masseudnyttet», kræver til gengæld at en privilegeret bruger udfører en handling (klikker på et craftet link til OAuth-consent-siden). OAuth-ruterne er live på sitet:

```
/wp-json/mcp/v1/.well-known/oauth-authorization-server   (offentlig metadata, 200)
/wp-json/mcp/v1/oauth/register                            (Allow: POST)
/wp-json/mcp/v1/oauth/authorize | /token | /revoke | /apps
```

Forbehold om ejerskab: `/mcp/v1` ligger ikke under AI Engines eget namespace (`mwai/v1`, hvor MCP-ruterne hedder `/mcp/status`, `/mcp/enable`, `/mcp/functions` osv.). Der er **tre** MCP-plugins installeret — AI Engine, **MCPWP 3.14.10** og **WPVibe 1.20.5** — så det er ikke afgjort hvilket plugin der står bag `/mcp/v1/oauth/register`. Det ændrer ikke konklusionen for AI Engine: 3.8.6 < 3.8.7 er omfattet uanset, og AI Engines egne MCP-ruter er også eksponeret. Det bør afklares i wp-admin (hvilket plugin har MCP slået til) før man konkluderer hvem der skal opdateres først.

3. Opdateringsplan

Anslået samlet tid: **~30 minutter**, hvoraf det meste er verifikation. Alt kan gøres af ejer/admin i wp-admin og Simply-panelet; intet kræver adgang til serveren.

#	Handling	Hvor	Tid
1	Notér nuværende version og tag screenshot af Plugins-listen (bevis hvis noget går galt)	wp-admin → Plugins	2 min
2	Opdatér AI Engine til 3.8.7+ (nyeste 3.8.9) via Dashboard → Opdateringer	wp-admin	5 min
3	Slå MCP fra i de plugins hvor det ikke bruges, og find ud af hvilket plugin der ejer /mcp/v1	wp-admin	5 min
4	Bloker changelog.txt og readme.txt for plugins i WAF'en — de afslører versioner	Simply kontrolpanel	10 min
5	Kør verifikationskommandoerne i afsnit 5	terminal	5 min
6	Tjek for ukendte administratorer og nye OAuth-klienter, hvis der er mindste tvivl (afsnit 4)	wp-admin	10 min
7	Skriv dato + version i docs/library/vedligehold-ugentlig-log.md og opdater denne fil	dette repo	3 min

Hvis opdateringen fejler (WAF, filrettigheder eller "download failed"): hent zip'en fra wordpress.org/plugins/ai-engine og upload manuelt via Plugins → Tilføj ny → Upload. Indtil det lykkes: slå MCP fra (trin 3) — det fjerner den konkrete angrebsflade uden at røre koden.

4. Tjekliste

Nu (i dag)

- [ ] Faktisk installeret version aflæst i wp-admin (snapshot siger 3.8.6 pr. 23/10)
- [ ] AI Engine opdateret til **3.8.7 eller nyere**
- [ ] Afklaret hvilket plugin der ejer `/mcp/v1`, og MCP slået fra hvor det ikke bruges
- [ ] `changelog.txt`/`readme.txt` blokeret i WAF
- [ ] Verifikation nedenfor kørt og output gemt

Efter opdatering (verifikation)

- [ ] WP's Plugins-liste viser 3.8.9 (eller nyeste)
- [ ] `/wp-json/mwai/v1/simpleAuthCheck` stadig `401` anonymt
- [ ] `/wp-json/mcp/v1` svarer **404/401** (MCP slået fra) — eller er bevidst beholdt
- [ ] Chatbotten på forsiden svarer stadig (opdateringen må ikke have brudt den)
- [ ] En AI-draft kan stadig genereres i Autopilot (deler AI-nøgle-sti med AI Engine, hvis samme nøgle bruges)

Forebyggelse

- [ ] Slå **auto-updates til for sikkerhedsrettelser** på AI Engine
- [ ] Abonnér på WPScan/Patchstack-mail for `ai-engine` og de øvrige plugins på sitet
- [ ] Tilføj "plugin-versioner" til den ugentlige vedligeholdelsesrutine — brug `/wp-json/wp/v2/plugins`, ikke `changelog.txt`
- [ ] Overvej at fjerne plugins der ikke bruges; hver aktiv plugin er en offentlig REST-namespace

Hvis der er mistanke om kompromittering

- [ ] Gennemgå Brugere for nye administratorer og ændrede roller
- [ ] Gennemgå OAuth-klienter under `/wp-json/mcp/v1/oauth/apps` og AI Engine → logs/discussions
- [ ] Rotér WordPress application passwords (Brugere → Profil) og AI-nøgler (Anthropic/OpenAI/AIMLAPI)
- [ ] Tjek Værktøjer → Site Health for ændrede filer, og sammenlign `wp-content/plugins` med wordpress.org's zip

5. Verifikationskommandoer (kun læsende)

```
BASE=https://steamgears.eu
# 1. Er simpleAuthCheck stadig lukket? (forventet: 401 rest_forbidden)
curl -s -o /dev/null -w '%{http_code}\n' "$BASE/wp-json/mwai/v1/simpleAuthCheck"

# 2. Er MCP stadig eksponeret? (forventet efter trin 3: 404)
curl -s -o /dev/null -w '%{http_code}\n' "$BASE/wp-json/mcp/v1"
curl -s "$BASE/wp-json/mcp/v1/.well-known/oauth-authorization-server" | head -c 120
```

Versionen kan **ikke** læses udefra: WAF'en blokerer `readme.txt`/`changelog.txt`/`.pot`, og `changelog.txt` er i øvrigt forældet. Aflæs den i wp-admin, eller genlæs `/wp-json/wp/v2/plugins` med admin-adgang som ved snapshotet 23/10.

Bemærk: en `POST` til `/wp-json/mcp/v1/oauth/register` **skal ikke** bruges som test — den opretter en OAuth-klient i produktionsdatabasen. Det er derfor fundet står som "omfattet", ikke "bekræftet udnytteligt".

6. Relateret på samme site

- Fuld versionsliste for alle 48 plugins med fokus på hvad der er bagud: sikkerhed-plugin-versioner-2026-11-01.md.
- `/wp-json/sgap/v1` svarer `200` → **Steamgears Autopilot er installeret live**, så `/snapshot`, `/stats`, `/feed` og `/queue` er offentligt nåbare ruter. De kræver application password (og `/feed` en feed-secret) — men de skal tjekkes med samme briller ved hver release.
- `/wp-json/`-indekset er 1,4 MB og lister alle namespaces (`mwai/v1`, `mcp/v1`, `rankmath/v1`, `wc/v3`, `sgap/v1`, ...). Det er standard WordPress og ikke et hul i sig selv, men det er den nemmeste måde for en angriber at se hvad der er installeret — derfor er versions-blokering i WAF'en i trin 4 stadig værd at gøre.

7. Kilder

- Patchstack — AI Engine <= 3.8.6, Privilege Escalation, CVE-2026-110732 [https://patchstack.com/database/wordpress/plugin/ai-engine/vulnerability/wordpress-ai-engine-mcp-server-ai-chatbot-for-wordpress-with-claude-chatgpt-gemini-plugin-3-8-6-missing-authorization-to-administrator-account-takeover-vulnerability] — CVSS 7.5, uautentificeret, patchet i 3.8.7, off. 29/10 2026
- WPScan — ai-engine plugin oversigt [https://wpscan.com/plugin/ai-engine/] — 44 sager, listen brugt i afsnit 2 (opdateret 31/10 2026)

- Wordfence Threat Intel — samme sag
  [https://www.wordfence.com/threat-intel/vulnerabilities/wordpress-plugins/ai-engine/ai-engine-the-chatbot-ai-framework-mcp-for-wordpress-386-missing-authorization-to-administrator-account-takeover-via-unauthenticated-mcp-oauth-client-registration]
- Versionsgrundlag: `backup-2026-10-23/plugins.json` (fra `/wp-json/wp/v2/plugins`, 48 plugins)